

Assignment-1

Get to know the existing cyber threats around!

- The task involves searching online for the cyberattacks that have happened **in the last 3 years** and filling in the Table below.
- You must search for and return the description for at least 5 cyberattacks.
- You can access authentic news, scientific articles, magazines, and blog post for reporting the attacks. Don't forget to mention the references.

No.	Name of the attack	About the attack <u>Question to answer:</u> 1. What kind of malware was used (virus/worm/spyware, etc.? 2. What was the targeted infrastructure? 3. When was the attack first executed? 4. If serial, when was it executed for the second time and onwards? 5. What was the total loss in terms of money? 6. What was the loss in terms of other attributes for instance reputations, and fines? 7. Was the same malware used in other places?	The skill of the attackers <u>Question to answer:</u> 1. Who were the attackers? 2. Were they ever caught? 3. Were they employees/ex-employees? 4. Is Anything known about the skill levels? 5. Was it an individual attempt or an organized cyber-attack (cyber terror) or a national government-sponsored attack (cyber war)	Add a brief explanation of the attack mechanism <u>Question to answer:</u> 1. How did the attack happen? 2. What was the vulnerability? 3. Was social engineering involved? 4. What was the attack vector? 5. Was the damage recovered?
1	The Internet Archive (Wayback Machine) Hack	1. This wasn't a traditional malware like a virus, worm. Instead, the attackers used exposed API keys and insecure JavaScript libraries to get in the internal systems. So it was a credential exploitation + DDoS. 2. User account systems (31M email addresses), the public web services (archive.org) 3. First executed on September 28, 2024, a database on user credentials were stolen 4. Secondly executed on 9 th of October 2024. This is when they did the public DDoS attack	1. "SN_Blackmeta" (Hacktivist group). 2. No, they weren't caught. 3. No, they exploited publicly exposed tokens and API keys. 4. Likely moderate-high, exploiting API tokens, authentication keys to access source code and support platforms are more competent cybersecurity skills. 5. It was an organized cyber-attack by a hacktivist group. Their reason of hacking was most likely to gain cyber street cred (reputation among hackers). They	1. Attackers discovered exposed API tokens in a GitLab configuration file, which had the credentials. With these keys hackers could download the source code and use them to access the user database. 2. Exposed unprotected API tokens. No warning after someone accessed them. 3. No social engineering. 4. Exposed API Token -> Database Access. 5. Damage was recovered, security was upgraded, site

		and disabled the Archive homepage. The final hack was on October 20th, when the hackers gained access to their Zendesk support email system. Tried gaining access to sensitive data. - Not publicly disclosed, and the hackers did not want any ransom demands. the Archive is non-profit, so unlikely much was actually lost. - Reputational damage: 31M user accounts hacked, trust is as a result lower. Public concerns about the security of archived materials and user privacy increased. The Wayback Machine went offline and only read-only for the duration of the hack, around 2 weeks. No fines yet, but breaches of personal data in US and EU can carry potential future fines. - This attack itself was not used in other major breaches (not a kind of malware to be reused globally). It was more about credential misuse, not common.	didn't actually make money from this hack.	was back, but the exposed user data cannot be un-leaked.
2	Disney (Nullbulge) Breach	- Info-stealer, on a developer's device, that had a credential-stealing functionality. - The target was Disney's internal Slack workspace used by	- A 25-year-old man called Ryan Kramer. - Yes he was caught. Kramer has pled guilty to illegal access and threatening to damage a	The attacker installed a malicious AI-image generator that collected data and credentials from any computer that installed it. A Disney employee

		developers and employees (messages, files, code) - Malware was distributed in January 2024, and the breach occurred in May 2024 and the data leaked in July 2024. - It wasn't a recurring attack, it was 1 extended incident. - No public information 1.1TB of internal Slack chats, meaning internal communication was exposed, unreleased project info, Disney and ESPN+ marketing strategies, leading to reputational and competitive loss. That employee that downloaded the malware had his personal identity and financial information leaked. - The malware author admitted that at least two other unrelated victims installed the same malicious file and had their systems compromised.	protected computer, and he faced 5 years in prison. - No, external - He showed above-average technical skills, being able to create a malware that stole credentials from installed systems. This was paired with social engineering skills - It was an individual cyberattack. Initially the hacker said it was a hacktivist attack to avoid the investigation going forward, but after arrest he admitted it was actually only him.	downloaded this program, giving the attacker access to that person's device and password manager. With those stolen credentials, Kramer then accessed Disney's Slack environment and downloaded 1.1 TB of internal data. - The vulnerability was a user-installed malware, as described earlier. - Yes. The attacker disguised the malware as a legitimate AI tool. He also communicated with the employee under false pretenses as part of the later extortion attempt. - Malicious App -> Cookie Hijacking -> Slack Access - The damage isn't recoverable as the information and data was exposed. As a result of this hack, Disney began removing Slack as its internal communication and replacing it with Microsoft Teams.
3	Bybit Crypto Hack	Malware: Malicious JavaScript code into the wallet interface used by Bybit signers. It wasn't a virus, it just manipulated the website's UI logic of transactions and refunds. The signers unknowingly approved a malicious transaction	- Lazarus Group (North Korea State-Sponsored) - No, they operate with North Korea protection. - No, from North Korea. - Very high-skilled team, they used sophisticated transaction manipulation and then	Attackers gained access to the developer infrastructure of the website, and injected some malicious JavaScript code that would change transaction details at the moment of signing. When signers were doing what they thought was a routine

		redirecting funds to attacker-controlled wallets. 2. Bybit's Ethereum exchange wallets (the ones with the most assets) 3. February 21, 2025, a routine transfer of Ethereum from a cold wallet (from a USB, offline) to a warm wallet (online wallet owned by hackers) 4. It was a single incident on Bybit. But the same group used similar tactics on other websites. 5. \$1.5 billion worth of cryptocurrency (Ethereum) was stolen, one of the the largest crypto hacks ever. 6. Bybit's security credibility took a major hit. Critics were questioning how easy it is to just manipulate UI. Mass withdrawal requests from users caused processing stress immediately after the hack. 7. The malware scripts are often reused/tweaked by this group.	laundering the money through decentralized exchanges. 5. State-Sponsored Cyber War.	transfer, the funds were instead sent to attacker wallets. 2. The compromise of the "multisig" wallet interface (the UI). 3. Reports suggest that the initial access might've needed social engineering, to gain access to a developer machine, but never confirmed. 4. Malicious Code Injection -> Ethereum to wallet -> use mixers to laundry the money. 5. Only around \$10M were actually recovered, with large amount of stolen crypto still being tracked by experts.
4	Collins Aerospace airport disruptions cyberattack	1. Ransomware attack. (HardBit) 2. The MUSE software platform provided by Collins Aerospace, the system that manages the electronic check-in, baggage drop and boarding operations used by Heathrow, Brussels, Berlin, Dublin. 3. Night of Friday, September 19, 2025. 4. Single major attack.	1. "Scattered Spiders" hack group. 2. 1 person was arrested 5 days later, but they were released on bail and investigation is still going. 3. No, they weren't. 4. Moderate to advanced. Deployed malware that can disable widely used systems and not alert any detection long enough to disrupt airport operations.	1. Attackers deployed ransomware to infect Collins Aerospace's MUSE check-in and boarding system infrastructure, making those systems inoperable. As a result, automated check-in kiosks, baggage drops, and boarding operations stopped working across affected airports.

		- Brussels Airport alone: €22 million in rerouted cargo Passenger compensation under EU261: Estimated €4.5 million Total industry impact: Potentially exceeding €150 million - Massive passenger delays, flights cancelled, total chaos at the airports, brand damage for the airports. Airports were forced into manual check-in, boarding. The attack found vulnerabilities in critical aviation infrastructure, lowering confidence in third-party systems for essential airport operations. - HardBit is a known ransomware type of hack and is used in other hacks too.	Organized cybercrime (Ransomware-as-a-Service)	- Ransomware infection, but precise entry vectors remain part of ongoing investigations. - Likely (to gain access to vendor credentials), although never confirmed. - Got in MUSE passenger processing system -> don't get detected -> make them inoperable. - Yes, airports recovered after 3-4 days.
5	Bank Sepah Hack	- Wiper (Malware) and data exfiltration malware (transfer data to hackers) - The core banking systems and online services of Bank Sepah, including account access and ATM networks. Payment systems connected to gas stations, military payroll, etc. It was state-owned bank. - March 2025 -> a group called "Codebreakers" stole terabytes of data related to millions of accounts and then attempted to ask for money from the bank. - Yes. On June 17 2025, a different group called	"Codebreakers" (March) and "Predatory Sparrow" (June). - No one. - No. - Elite / Nation-State level (suspected Israeli Intelligence). - Cyber War (happened during Iran and Israel war)	- Technical details are not publicly available not even today. It is likely that attackers breached the supply chain (Tosan provider) to gain access, then exfiltrated data before destroying the network with wipers. - The Centralized Banking Software (once this fails, everything fails) - Unknown, but not likely. - Supposedly Breach Supply Chain -> exfiltrate data -> destroy with wipers. - After temporary outages, some services were

		Predatory Sparrow they disrupted operations and destroyed data. - Not publicly available, but the group from March was asking for \$42M in Bitcoin as ransom, but the bank ignored. - The bank's claims of "unhackable systems" were widely questioned after the hack. The security of critical financial infrastructure in Iran was a question mark, as 126M accounts were leaked. Customers had ATM outages, payment systems weren't working. - Hacking method was similar to the previous "MeteorExpress" hack, that disrupted the Iranian train system.		restored. But sensitive customer information was quickly listed on Telegram.
--	--	--	--	---

– The questions provide you with a description of what information is desired in each field, you can add extra information if you desire to do so.

Sources:

Internet Archive - <https://www.bleepingcomputer.com/news/security/internet-archive-breached-again-through-stolen-access-tokens/>

Disney Hack - <https://www.wsj.com/tech/cybersecurity/disney-employee-ai-tool-hacker-cyberattack-3700c931>

Bybit Hack - <https://www.trmlabs.com/resources/blog/the-bybit-hack-following-north-koreas-largest-exploit>

Collins Aerospace - <https://breached.company/breaking-down-the-collins-aerospace-cyber-attack-a-wake-up-call-for-aviation-security/>

Bank Sepah - <https://www.cyfluence-research.org/post/codebreakers-hack-sepah-bank-financial-motive-or-influence-operation>

Declaration of AI usage: No AI tools were used in the homework.

